COMPTIA SECURITY+ SY0-701 | DOMAIN 1 · GENERAL SECURITY CONCEPTS (12%)

Security+ 1.2 · Zero Trust

Mestre CyberSec · **Lesson 1.2 — Zero Trust** (10:04) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Zero Trust: NUNCA confie, SEMPRE verifique. Todo acesso é autenticado/autorizado por identidade + saúde do dispositivo + contexto (não 'estou dentro da rede, então confio'). Micro-segmentação = cada carga isolada. CAE (Continuous Access Evaluation) revoga sessão em segundos quand

💡 Key Exam Highlights & Critical Concepts

- Never trust, always verify — mesmo interno
- 3 pilares: Identidade (IAM/MFA), Dispositivo (MDM/EDR), Rede (microssegmentação)
- CAE revoga sessão em tempo real (não espera token expirar)
- Zero Trust ≠ produto — é ARQUITETURA

🎯 Exam Tips & Typical CompTIA Scenarios

- Cenário com 'even inside the network' = zero trust
- 'continuous access evaluation' / 'revokes in real time' = CAE

🧯 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 1.2 — Zero Trust)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Zero Trust Architecture (ZTA)

Security architecture model where no user, device, or connection is trusted by default — every access request must be continuously authenticated and authorized based on identity, device health, and context.

⚠️ ***Exam Trap:*** *Gatilho: 'even inside the network' ou 'internal users must also be verified' = Zero Trust. Lembre: é ARQUITETURA/estratégia, não produto que se compra. Não confunda com VPN ou firewall.*

• Continuous Access Evaluation (CAE)

Mechanism that continuously re-evaluates active sessions and revokes access in near real time when risk conditions change (location, device compliance, account compromise), without waiting for token expiration.

⚠️ ***Exam Trap:*** *Gatilho: 'revoke access in real time', 'immediately terminate session', 'without waiting for token to expire' = CAE. Diferença chave: autenticação tradicional valida só no login; CAE valida DURANTE a sessão.*

• Micro-segmentation (N/A)

Dividing the network into very small isolated zones (down to individual workloads) so that each segment requires its own authentication/authorization, preventing lateral movement by attackers.

⚠️ ***Exam Trap:*** *Gatilho: 'prevent lateral movement', 'isolate each workload', 'east-west traffic' = microssegmentação. Distinga de VLAN tradicional: microssegmentação é granular por workload/aplicação, não só por sub-rede.*

• Policy Enforcement Point (PEP)

The gatekeeper component in the data plane that enforces the access decision — allowing, denying, or terminating connections between subjects and enterprise resources based on instructions from the policy engine.

⚠️ ***Exam Trap:*** *Gatilho: 'what enforces/blocks the connection' = PEP. Macete: PEP está no DATA plane e EXECUTA; a DECISÃO vem do Policy Engine (control plane). Não troque os papéis.*

• Policy Engine (PE) / Policy Administrator (PA) (PE/PA)

The Policy Engine makes the trust/access decision by evaluating identity, device posture, and context; the Policy Administrator then communicates that decision to the PEP to establish or terminate the connection path.

⚠️ ***Exam Trap:*** *Gatilho: 'decides whether to grant access' = Policy Engine (decide); 'configures the connection path/tells the PEP' = Policy Administrator (comunica). PE decide → PA instrui → PEP executa.*

• Control Plane vs. Data Plane (N/A)

Zero Trust's two planes of operation: the control plane handles policy decisions and authentication logic (PE, PA, adaptive identity), while the data plane carries actual traffic through enforcement points (PEP) to resources.

⚠️ ***Exam Trap:*** *Gatilho: cenário perguntando ONDE a decisão acontece = control plane (pensa/decide); ONDE o tráfego passa = data plane (age/transporta). Adaptive identity, threat scope reduction e policy-driven access control = control plane.*

• Adaptive Identity and Device Posture (IAM/MFA/MDM/EDR)

The three Zero Trust verification pillars: strong identity (IAM with MFA), device health/compliance validation via MDM/EDR, and contextual signals — all evaluated before and during access.

⚠️ ***Exam Trap:*** *Gatilho: 'verify device health before granting access' = device posture (MDM/EDR). A prova mistura: identidade (O QUEM você é) + postura (QUAL a saúde do dispositivo) + contexto (de onde/quando). Faltou um pilar, não é Zero Trust completo.*

• Implicit Trust Zone (N/A)

In legacy perimeter-based security, the internal network area where all traffic is automatically trusted; Zero Trust eliminates implicit trust zones so nothing is trusted by default, internal or external.

⚠️ ***Exam Trap:*** *Gatilho: 'trusted internal network' ou 'everything behind the firewall is trusted' descreve o PROBLEMA (zona de confiança implícita) que Zero Trust resolve. Se a questão pede eliminar confiança automática interna = Zero Trust.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 The Core Philosophy: 'Never Trust, Always Verify'

🏠 **Real-World Analogy:** Legacy security was like a medieval castle with a moat and drawbridge: anyone outside was treated as an adversary, but anyone crossing the bridge was implicitly trusted to wander freely into any bedroom or treasury. Zero Trust is a modern international embassy: whether standing on the exterior sidewalk or walking down the 3rd-floor executive corridor, every single interior door demands passport validation, biometric verification, and continuous business justification.

🔍 **Root Cause & Background:** The traditional physical perimeter vanished with remote work, mobile devices, and multi-tenant cloud SaaS. Furthermore, on flat legacy networks, once an attacker breached an entry-level workstation via phishing, they roamed laterally unimpeded until seizing Domain Controller control.

🛡️ **GRC Auditor Perspective:** Auditors evaluate compliance against NIST SP 800-207 (Zero Trust Architecture): verifying the total elimination of implicit trust based on physical location or internal IP subnets, mandating that every access transaction is authenticated, authorized, and encrypted based on dynamic identity and device health context.

⚠️ **How CompTIA Tests This:** Core CompTIA motto: 'Never trust, always verify'. Exam cue: 'An organization assumes all network traffic, even originating from internal office LANs, is potentially compromised and evaluates every transaction dynamically'. Target answer: Zero Trust Architecture (ZTA).

📌 Control vs. Data Plane: PDP (Policy Decision Point) and PEP (Policy Enforcement Point)

🏠 **Real-World Analogy:** An automated airport biometric border gate. The central immigration database evaluating Interpol watchlists, flight manifests, and visa validity is the PDP (Policy Decision Point: the analytical brain evaluating rules to issue an allow or deny verdict). The motorized bulletproof glass turnstile standing directly in front of the traveler is the PEP (Policy Enforcement Point: the physical enforcer executing the decision, opening only when authorized).

🔍 **Root Cause & Background:** Hardcoding fragmented, static rules manually across dozens of disparate routers and firewalls led to massive security drift and inconsistent policies. Decoupling the centralized policy engine (PDP) from distributed enforcement gateways (PEP) enables coherent, instantaneous policy orchestration.

🛡️ **GRC Auditor Perspective:** Auditors review Conditional Access infrastructure: inspecting policy logic configured within the central PDP (e.g., Microsoft Entra ID Conditional Access or Okta Policy Engine) and validating that all inbound resource traffic terminates strictly through an authenticated PEP proxy (e.g., ZTNA gateway, reverse proxy, or SASE edge).

⚠️ **How CompTIA Tests This:** High-frequency CompTIA questions: 'Which component in Zero Trust evaluates identity, compliance state, and context to grant or deny an access request?' -> PDP (Policy Decision Point). 'Which component terminates the session and enforces the allow/block verdict at the boundary?' -> PEP (Policy Enforcement Point).

📌 Microsegmentation: Stopping Lateral Movement

🏠 **Real-World Analogy:** The automated watertight bulkheads and blast doors of a naval submarine. If a torpedo punctures the hull flooding the auxiliary engine room, automated pressure doors seal that single flooded compartment instantly, preventing seawater from spreading and sinking the entire vessel.

🔍 **Root Cause & Background:** In unsegmented flat legacy enterprise networks, ransomware or an APT compromising a single front-desk computer could easily propagate across peer workstations via local broadcast/SMB traffic, systematically encrypting every internal datacenter host.

🛡️ **GRC Auditor Perspective:** Auditors validate Software-Defined Perimeter (SDP) and microsegmentation rules (via host-based firewalls and Kubernetes network policies), verifying that uninspected lateral peer-to-peer communication (East-West traffic) is blocked by default under a strict Zero Trust stance.

⚠️ **How CompTIA Tests This:** Unbeatable CompTIA exam triggers: 'Prevent lateral movement of an adversary within the internal network', 'Isolate individual workloads and containers', 'Granular filtering of internal East-West traffic'. Target answer: Microsegmentation.

📌 Continuous Access Evaluation (CAE): Real-Time Adaptive Security

🏠 **Real-World Analogy:** The driver alertness sensor and seatbelt monitor in a modern autonomous vehicle. It is not enough to buckle your seatbelt once when starting the ignition; if you unbuckle mid-journey while cruising at 65 mph or nod off for 3 seconds, the vehicle triggers urgent audible alarms, restricts throttle, and brings the car to a safe stop.

🔍 **Root Cause & Background:** Legacy authentication systems granted access tokens valid for 8 to 24 hours upon initial login. If an employee was terminated or their device compromised 10 minutes into the workday, the session token remained active, giving adversaries hours of unrestricted access.

🛡️ **GRC Auditor Perspective:** Auditors test identity provider Continuous Access Evaluation (CAE) configurations: simulating user credential revocation or high-risk telemetry triggers (e.g., Impossible Travel detections) to verify that active cloud sessions are terminated in near real-time across all SaaS applications.

⚠️ **How CompTIA Tests This:** Exam scenario cue: 'An authenticated user's active cloud session is revoked in real time when their endpoint becomes non-compliant or password is changed, without waiting for token expiration'. Target answer: Continuous Access Evaluation (CAE).

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Philosophy treating all network traffic as untrusted, even traffic from the internal LAN	**Zero Trust Architecture (Never Trust, Always Verify)**
Central engine that examines identity, posture, and context to approve or deny access	**PDP (Policy Decision Point)**
Gateway component that intercepts client traffic and enforces allow or block actions	**PEP (Policy Enforcement Point)**
Granular isolation of workloads and servers to block attackers from moving laterally	**Microsegmentation**
Instantly terminating an active user session the moment their endpoint health drops	**Continuous Access Evaluation (CAE)**
Temporary elevation of administrative privileges granted strictly for maintenance window	**Just-In-Time Access (JIT / Dynamic Least Privilege)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A retail company is concerned that ransomware on a web server could spread to its database and payment services because all three workloads currently share the same internal subnet. The security team wants each workload to communicate only with the specific services it needs, even if an attacker gains a foothold in one workload. Which Zero Trust concept should they implement?

A) Implicit trust zone

B) Micro-segmentation

C) Single sign-on federation

D) Full-disk encryption

QUESTION 2 · EXAM SCENARIO

An employee authenticates with MFA and a compliant laptop to a cloud CRM. Ten minutes later, the endpoint detection and response tool reports that the laptop is infected with credential-stealing malware. The security team wants the active CRM session terminated immediately rather than waiting for the token to expire. Which capability best meets this requirement?

A) Kerberos ticket caching

B) OAuth refresh token rotation only

C) Continuous Access Evaluation

D) Static network access control lists

QUESTION 3 · EXAM SCENARIO

A Zero Trust architecture separates access decisions from traffic enforcement. A user's request includes identity, device health, location, and resource sensitivity. Which component evaluates these attributes against policy and determines whether access should be granted, denied, or revoked?

A) Policy Enforcement Point

B) Data plane gateway

C) Policy Engine

D) Security information and event management system

QUESTION 4 · EXAM SCENARIO

A company wants to enforce Zero Trust policy at the boundary of each application. The chosen component must intercept connection requests, query the control plane, and allow or block the session before traffic reaches the protected service. Which component performs this function?

A) Policy Engine

B) Identity provider

C) Certificate authority

D) Policy Enforcement Point

QUESTION 5 · EXAM SCENARIO

A legacy datacenter design treats every device connected to the internal switch as trusted. Consultants warn that an attacker who compromises one internal workstation could move freely to sensitive systems. Which Zero Trust weakness is most directly illustrated?

A) Least privilege

B) Implicit trust zone

C) Defense in depth

D) Federated identity

QUESTION 6 · EXAM SCENARIO

A user has a valid MFA token and correct role, but the laptop lacks a critical operating system patch and has disk encryption disabled. The access policy should deny the user from opening the financial reporting application. Which Zero Trust input is most directly responsible for this denial?

A) Password complexity

B) Domain name reputation

C) Device posture

D) Switch port security

QUESTION 7 · EXAM SCENARIO

A cloud administrator wants access decisions to consider not only who the user is but also whether the request comes from an unmanaged device, an unusual country, or a high-risk network. Which Zero Trust capability is being described?

A) Network address translation

B) Static role-based access control

C) Full packet capture

D) Adaptive identity and context-based access

QUESTION 8 · EXAM SCENARIO

In a Zero Trust design, the Policy Engine and Policy Administrator make decisions and configure sessions, while the Policy Enforcement Point handles actual traffic. Where do the Policy Engine and Policy Administrator logically reside?

A) Data plane

B) Control plane

C) Forwarding plane

D) Endpoint execution plane

QUESTION 9 · EXAM SCENARIO

After the Policy Engine decides that a contractor may access a specific internal application for 30 minutes, a component must establish the allowed communication path and configure the enforcement point for that session. Which component performs this role?

A) Policy Engine

B) Identity provider

C) Policy Administrator

D) Endpoint detection and response

QUESTION 10 · EXAM SCENARIO

A security architect must explain where policy is actually enforced on live traffic in a Zero Trust architecture. Which plane contains the Policy Enforcement Point that allows or blocks user-to-resource connections?

A) Control plane

B) Management plane

C) Data plane

D) Identity plane

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Micro-segmentation

Micro-segmentation divides the environment into small, isolated zones or workloads and enforces least-privilege communication between them. This limits lateral movement even when workloads are on the same broader network. Implicit trust zone is the opposite problem, SSO addresses identity federation, and full-disk encryption protects data at rest but does not restrict east-west traffic.

Question 2: Option C — Continuous Access Evaluation

Continuous Access Evaluation (CAE) enables real-time re-evaluation of access decisions when risk signals such as EDR alerts, user location, or device posture change. It can revoke sessions in near real time. Kerberos caching, OAuth refresh token rotation, and static ACLs do not provide immediate risk-based session revocation across cloud applications.

Question 3: Option C — Policy Engine

The Policy Engine (PE) is the decision component. It evaluates subject, device, context, and resource attributes against organizational policy. The Policy Enforcement Point enforces the decision, the data plane carries traffic, and a SIEM correlates logs rather than making per-request access decisions.

Question 4: Option D — Policy Enforcement Point

The Policy Enforcement Point (PEP) sits in the data path and enforces the access decision by allowing, denying, or modifying connections. The Policy Engine makes the decision, while the identity provider and certificate authority support authentication and trust but do not enforce per-request access to the application.

Question 5: Option B — Implicit trust zone

An implicit trust zone exists when access is granted because a device or user is inside a network boundary, without verifying identity, device health, or context. Zero Trust rejects this assumption. Least privilege, defense in depth, and federated identity are related concepts but do not describe the specific mistake of trusting the internal network by default.

Question 6: Option C — Device posture

Device posture includes compliance and health signals such as patch level, disk encryption, EDR status, and firewall state. Zero Trust evaluates these signals along with identity and context. Password complexity, domain reputation, and switch port security may support security but do not represent the endpoint health condition that caused the denial.

Question 7: Option D — Adaptive identity and context-based access

Adaptive identity and context-based access use multiple signals, including user identity, device management state, location, time, and risk, to make dynamic access decisions. NAT, static RBAC, and full packet capture do not dynamically evaluate request context for authorization.

Question 8: Option B — Control plane

The Policy Engine and Policy Administrator are part of the control plane because they decide and orchestrate access. The Policy Enforcement Point operates in the data plane to enforce those decisions on traffic. Forwarding plane is a networking term closely related to data plane, and endpoint execution plane is not the standard ZTA separation.

Question 9: Option C — Policy Administrator

The Policy Administrator (PA) acts on the Policy Engine's decision. It creates, modifies, or tears down the communication path and configures the Policy Enforcement Point for the session. The Policy Engine makes the decision, the identity provider authenticates, and EDR provides endpoint risk telemetry.

Question 10: Option C — Data plane

The Policy Enforcement Point resides in the data plane because it processes live traffic and enforces allow/deny decisions. The control plane contains decision and orchestration functions such as the Policy Engine and Policy Administrator. Management and identity planes are not the standard location for the PEP in ZTA.